SOC 2 Compliance Checklist: A Step-By-Step Guide for 2025 (+ Audit Best Practices)

What's Inside

This easy-to-follow SOC 2 compliance checklist will help your organization prepare for and maximize the chance of passing an audit.

Get Started With Drata Automate SOC 2 Watch Stories View Integrations Get a Demo

CONTENTS

What is a SOC 2 Compliance Checklist?

Download Drata's SOC 2 Audit Checklist

9-Step SOC 2 Compliance Checklist

SOC 2 and the Trust Services Criteria

What are the Benefits of SOC 2 Compliance?

SOC 2 Audit Prep Best Practices

Streamline Your SOC 2 Compliance With Drata

SOC 2 Compliance: Frequently Asked Questions (FAQs)

For companies that handle sensitive data, earning and maintaining customer trust hinges on one thing: strong security practices. While not a mandatory requirement, System and Organization Control 2 (SOC 2) compliance has quickly become a gold standard in data security.

Unfortunately, you can't get a SOC 2 badge from a cereal box. Compliance is verified through a rigorous third-party audit, where an independent assessor evaluates whether your organization's security controls meet the criteria defined by the American Institute of Certified Public Accountants (AICPA).

The end result is a detailed report that attests to the effectiveness of your security practices—giving your customers and partners confidence that you're protecting their data, and you, a hard-earned badge to brag about.

It may seem overwhelming, but it doesn't have to be. We've created this easy-to-follow checklist to help you start your journey to SOC 2 compliance.

TL;DR: *A SOC 2 compliance checklist helps organizations prepare for certification by outlining the essential steps and controls. It covers defining the audit scope, identifying applicable Trust Services Criteria, conducting a readiness assessment, implementing technical and administrative controls, developing security policies, training staff, managing vendors, performing risk assessments, and working with a licensed auditor.*

What is a SOC 2 Compliance Checklist?

A SOC 2 compliance checklist is a roadmap that helps your team prepare for the audit by breaking down exactly what needs to be done, from setting up access controls to collecting evidence and documenting processes.

Each step in the checklist aligns with the Trust Services Criteria (TSC): Security, Availability, Processing Integrity, Confidentiality, and Privacy. It keeps your audit on track and surfaces gaps early, so that nothing slips through the cracks.

Download Drata's SOC 2 Audit Checklist

We've created a helpful SOC 2 checklist PDF to reference as you begin the SOC 2 compliance journey. You can download it at the link below.

Download Your SOC 2 Checklist

Get ready for your SOC 2 with these nine, easy-to-follow steps.

Download Now

9-Step SOC 2 Compliance Checklist

What goes into the preparation and execution of a SOC 2 audit? These are the steps you can expect to take and more details about what to do during each part of the process:

1. Determine if a Type 1 is Necessary
2. Evaluate Your Scope
3. Communicate Processes Internally
4. Perform a Gap Assessment
5. Remediate Control Gaps
6. Update Your Customers and Prospects
7. Monitor and Maintain Controls
8. Find an Auditor
9. Undergo the SOC 2 Audit

1. Determine if a Type 1 Is Necessary

To get started with SOC 2, the first step is to determine if you would like the auditor to perform a SOC 2 Type 1 audit prior to performing a more rigorous SOC 2 Type 2 audit.

- When performing a SOC 2 Type 1 audit, auditors review policies, procedures, and control evidence to determine if controls are suitably designed to meet the applicable SOC 2 criteria. The Type 1 audit covers a point in time, and the resulting report will state whether or not controls were suitably designed as of a specific date.
- A SOC 2 Type 2 audit is much more rigorous. In addition to determining if controls were suitably designed, auditors will also review evidence to determine that controls were operating effectively over a period of time to meet the applicable SOC 2 criteria.

	Type 1	**Type 2**
What it covers	Design of controls	Design and operating effectiveness
Audit timeframe	Single point in time	Minimum three month observation period
Timeline	One to two months (on average)	Three to, 12 months depending on scope
Cost	$7,500 to $60,000, depending on company size	$12,000 to $100,000, depending on company size

Because of the nature of Type 1 versus Type 2 audits, organizations will typically engage an auditor to perform a Type 1 audit prior to a Type 2 audit. However, Type 1 audits do not need to be performed prior to completing a Type 2—organizations can choose to undergo a Type 2 audit without ever undergoing a Type 1 audit.

Customers will typically accept a Type 1 report for their vendors undergoing a SOC 2 audit for the first time, but they will more than likely expect a Type 2 report moving forward.

2. Evaluate Your Scope

SOC 2 audits evaluate the effectiveness of your organization's security controls across the following components: infrastructure, data, procedures, software, and people. The first step is to define which system components are in scope.

You'll also need to decide which Trust Services Criteria (TSC) to include in your audit. As discussed earlier, security is mandatory for all SOC 2 audits, but the other criteria—Confidentiality, Availability, Processing Integrity, and Privacy—should be selected based on the nature of your business and customer expectations. For example:

- Include Availability if your customers rely on your systems or services to be accessible around the clock (e.g., SaaS platforms or cloud service providers).
- Include Processing Integrity if your systems are responsible for processing transactions or data where accuracy and authorization are critical (e.g., payment processing systems).
- Include Privacy if your business collects and manages personally identifiable information (e.g., healthcare or HR data).

3. Communicate Processes Internally

Communicating internally with key players is imperative throughout your SOC 2 audit planning process. Your organization's executive management and department leaders (human resources, engineering, DevOps, cybersecurity, IT, etc.) will be responsible for implementing your SOC 2 controls and providing evidence to the auditor.

Explaining the who, what, when, where, why, and how of the audit is crucial to preparing employees for their obligations.

4. Perform a Gap Assessment

A gap assessment, sometimes called a readiness assessment, helps you determine how close your organization is to meeting SOC 2 requirements. It's a detailed review of your existing security controls, policies, and procedures, measured against the Trust Services Criteria (TSC) relevant to your business.

What to evaluate:

- **Existing controls:** Are they clearly defined, documented, and consistently followed?
- **Policy coverage:** Do you have formal policies in place for security, access control, incident response, and vendor management?
- **Evidence availability:** Can you prove your controls are working (via logs, tickets, reports, or screenshots)?

You can conduct a gap assessment internally using a compliance platform or bring in a consultant for an outside perspective. Whichever route you take, the goal is to compare your current controls and documentation against SOC 2 requirements, identify what's missing, and prioritize remediation.

The output should be a clear list of gaps mapped to the relevant Trust Services Criteria, along with recommended actions and an estimated timeline to close them.

5. Remediate Control Gaps

Once your gap assessment has been completed, remediating and ensuring SOC 2 control mandates are being achieved can take time. This is often the most time-consuming and important part of the process. Effective remediation ensures that your organization aligns with the selected Trust Services Criteria before the audit begins.

You'll need to collaborate with department leads to:

- **Review and update existing policies** to ensure they meet SOC 2 requirements
- **Document and formalize operational procedures** for consistent execution
- **Adjust configurations or system settings** in identity management, logging, monitoring, and backups
- **Implement new tools or workflows** to fill technical or process gaps, such as onboarding automations, vulnerability scanners, or ticketing systems
- **Establish ownership** for ongoing monitoring of each control

DRATA

11 Steps to Prepare, Achieve, and Maintain SOC 2 Compliance

STEP 01

Decide Between SOC 2 Type 1 and Type 2

STEP 02

Define Your Scope

STEP 03

Align Internally

STEP 04

Conduct a Gap Assessment

STEP 05

Remediate Gaps

STEP 06

STEP 07

Implement Continuous Monitoring

STEP 08

Choose the Right Auditor

STEP 09

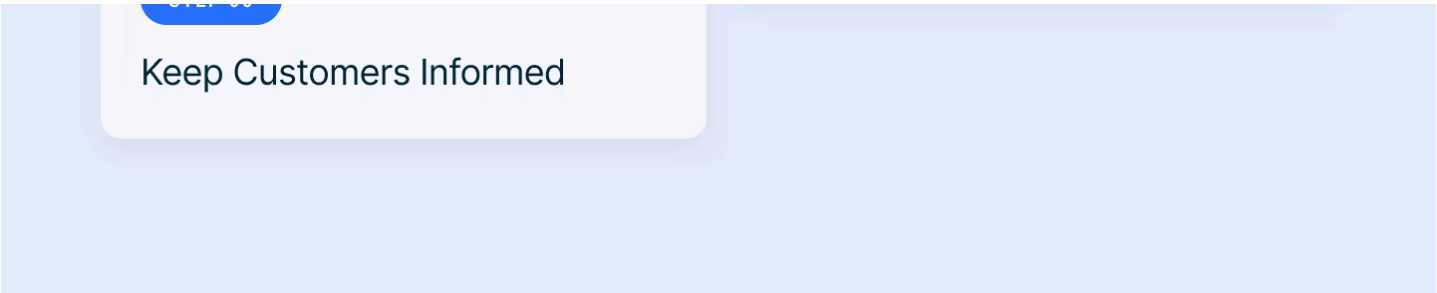
Complete the Audit

STEP 10

Maintain Compliance Year-Round

STEP 11

Showcase Compliance with a Trust Center



graphic showing 11 steps to prepare achieve and maintain soc 2 compliance

6. Update Your Customers and Prospects

In the spirit of transparency and building trust, discuss with your team a few ways to promote your security practices with customers and prospects. Although you don't have to announce that you're pursuing SOC 2, you can still outline the processes you have in place to keep their data safe.

On your website, social media, or Trust Center, consider outlining a high-level overview of:

- Any continuous security control monitoring you have in place.
- Employee training.
- Penetration testing you've conducted.
- Data encryption procedures.

7. Monitor and Maintain Controls

Once your controls are in place, your team should establish processes to track their effectiveness, maintain documentation, and collect evidence continuously. This includes:

- **Implementing monitoring tools** that track access, system changes, incident response, and vendor activity
- **Setting control review cadences** (e.g., quarterly access reviews, annual policy updates)
- **Automating evidence collection** where possible to reduce manual work and audit prep time
- **Creating alerting systems** to flag deviations or lapses in controls

SOC 2 Type 2 audits, in particular, require proof that controls operate effectively over time, not just that they exist. Without continuous monitoring, you risk falling out of compliance between audits.

Pro tip: Use a compliance platform that logs evidence automatically and surfaces issues in real time so you can cut down prep time and lower the chance of missing something during your audit window.

8. Find an Auditor

Before you begin looking for an audit firm, it's important to determine what you're looking for in an auditor. The right auditor can do much more than conduct your audit—they can help you understand and improve your compliance programs, streamline the process, and ultimately achieve a clean SOC 2 audit report.

Look for someone who:

- Answers your questions intelligently and in a way your team understands.
- Understands your industry.
- Collaborates well with you and your team and has strong references.

For more tips, head to our article on how to find the right auditor.

9. Undergo the SOC 2 Audit

At this stage, you're ready to begin the audit process. Your chosen CPA firm will assess whether your controls meet the criteria you scoped and whether they're operating as intended (for Type 2). A platform with features like Drata's Audit Hub helps you streamline communication and evidence sharing, so you're not chasing down requests or losing track of what's been submitted.

What to expect during the audit:

- **Evidence review:** Your auditor will examine documentation, logs, policies, and system outputs for each in-scope control
- **Walkthroughs and interviews:** Auditors may schedule sessions with control owners to verify how processes work in practice
- **Request management:** Be prepared for follow-up questions or requests for additional artifacts
- **Audit duration:** Most SOC 2 Type 1 audits take a few weeks; Type 2 audits involve reviewing data from a three to 12-month period.

Once the review is complete, your auditor will deliver a SOC 2 report, summarizing their findings, listing any exceptions, and confirming whether your organization met the applicable Trust Services Criteria.

SOC 2 and the Trust Services Criteria

When preparing for a SOC 2 audit, one of the first things you'll need to determine is which Trust Services Criteria (TSC) are relevant for your organization. The TSC, defined by AICPA, set the standard for the controls you need to manage risk and protect your organization's data.

There are five Trust Services Criteria: Security, Availability, Processing Integrity, Confidentiality, and Privacy. Every SOC 2 audit must include Security, but the other criteria can be added based on the specific needs of your business and your customers' expectations.

Security

Security, the only mandatory criteria, focuses on protecting systems and information from unauthorized access, disclosure, and damage. Security controls are designed to ensure the availability, integrity, and confidentiality of your data.

In 2013, the Committee of Sponsoring Organizations (COSO) introduced a framework consisting of nine control areas, known as the common criteria or CC series:

- CC1 - Control environment: Involves setting the tone for security within an organization by defining security roles, responsibilities, and policies

- CC2 - Information and communication: Requires that relevant information about security policies and incidents is communicated clearly across the organization
- CC4 - Monitoring: Involves regularly monitoring and evaluating the performance of security controls to identify any gaps or issues
- CC3 - Risk assessment: Requires the implementation of a structured process to identify, analyze, and respond to security risks that could impact the organization's objectives
- CC5 - Control activities: Entails the development of specific procedures, such as access management and system configurations, to mitigate identified security risks
- CC6 - Logical and physical access: Requires organizations to restrict access to systems and data based on user roles and responsibilities, so that only authorized personnel can access sensitive information both logically (via software and networks) and physically (via secure facilities)
- CC7 - Controls system operations: Focuses on verifying that systems are operating as intended, including the management of daily operations, incident response, and maintaining the availability and integrity of systems and data
- CC8 - Change management: Involves controlling how changes to systems, applications, and infrastructure are implemented, so that they don't introduce new security risks or affect system performance
- CC9 - Risk mitigation: Entails establishing processes and safeguards to reduce the impact of security risks that have been identified, as well as planning for and responding to security incidents effectively

This framework guides organizations in designing and assessing their internal controls. Of the nine criteria, the first five are essential for establishing a strong security posture.

Availability

Availability ensures your systems are operational and accessible as agreed upon in service-level agreements (SLAs). It focuses on maintaining system uptime and minimizing downtime.

While not mandatory, including Availability in your SOC 2 scope signals to customers that you prioritize keeping your systems reliable and that you have plans in place to handle disruptions.

It's broken down into three criteria:

- A1.1 - Involves continuously monitoring and evaluating current system capacity—including infrastructure, data, and software—so the organization can anticipate demand and scale effectively
- A1.2 - Covers the design, implementation, and ongoing management of environmental protections, backup processes, and recovery systems to maintain availability under normal conditions and during unexpected events
- A1.3 - Ensures regular testing of recovery procedures to verify that system restoration and data recovery processes work as intended and meet availability requirements

Processing Integrity

Processing Integrity means that your system processes data in a way that's complete, accurate, and timely. This is an important principle if your business involves high-volume transactions, automated data processing, or complex data management.

The five Processing Integrity controls are:

- PI1.1 - Establishes clear definitions and specifications for data and systems to support the accurate use and delivery of products and services.
- PI1.2 - Requires policies and procedures that ensure all data inputs are complete, accurate, and meet defined integrity objectives.
- PI1.3 - Ensures processing activities are well-defined, controlled, and monitored to maintain data integrity and correct any errors promptly.
- PI1.4 - Mandates safeguards that ensure data outputs are complete, accurate, delivered securely, and only to authorized parties.
- PI1.5 - Focuses on protecting stored data and maintaining accurate records of all inputs, processes, and outputs within the system.

Confidentiality

The Confidentiality criteria protects sensitive data from unauthorized access or disclosure. This applies to any information classified as confidential—whether it's trade secrets, financial information, or client data.

The Confidentiality subcriteria establish how to manage and protect confidential data:

- CC1.1 - Requires identifying and classifying confidential information to apply appropriate protections, with clear accountability for managing and safeguarding the data
- CC1.2 - Mandates controls that protect confidential information throughout its lifecycle, including access restrictions, encryption, secure transmission, monitoring, and secure disposal

Privacy

The Privacy criteria is about protecting personal data according to your organization's policies and applicable regulations like GDPR and CCPA.

There are several privacy controls, organized into eight categories:

- Notice - Organizations must provide clear privacy notices to individuals, informing them how their personal data will be collected, used, and stored.
- Choice and consent - Individuals must be given options regarding how their data will be used, and their consent must be obtained.
- Collection - Only data necessary for the stated purposes should be collected, and organizations must ensure it is gathered lawfully.
- Use, retention, and disposal - Personal data should only be used for its intended purpose, retained for as long as necessary, and disposed of securely when no longer needed.
- Access - Individuals must be able to access and correct their personal data, and organizations must authenticate users before granting access.
- Disclosure and notification - Organizations must control how personal data is shared with third parties and notify affected individuals in case of breaches.
- Quality - Data must be relevant, accurate, and up-to-date for its intended use.
- Monitoring and enforcement - Mechanisms must be in place to monitor compliance with privacy controls, handle complaints, and address issues.

New to SOC 2?

Learn how to get started and save time with our Start-to-Finish SOC 2 Guide.

Download Now

What are the Benefits of SOC 2 Compliance?

SOC 2 compliance is a strategic investment in your organization's credibility, security, and growth. Let's break down its impact further.

SOC 2 Compliance Builds Customer Trust

Customers are more cautious than ever about how their data is handled. McKinsey speaks of a "privacy imperative," after one survey revealed that 87% of customers would not do business with a company if they had concerns about its security practices. Organizations are catching up fast to meet expectations, with some increasing privacy budgets to the tune of $2.7 million in 2022.

SOC 2 compliance is one piece of the larger trust equation. It requires stringent controls that, if implemented, send a clear message to your customers: we take data protection seriously.

With data breaches making headlines on the regular, being SOC 2 compliant positions your organization as a trustworthy partner.

SOC 2 Compliance Sets You Apart from the Competition

Unlike HIPAA or GDPR, SOC 2 isn't a legal compliance requirement, but that's what makes it so impactful. A SOC 2 badge is actual, tangible proof that your organization has gone above and beyond to implement and validate its security controls, even when it's not mandated by law.

When prospects are choosing between multiple options, SOC 2 compliance can very well be the credential that tips the scales in your favor—one that sets your business apart as a safer, more reliable choice.

SOC 2 Compliance Opens Up Growth Opportunities

If the differentiator argument isn't enough to sway you, consider what happens without it. In highly regulated industries like finance and healthcare, SOC 2 isn't just a point in your favor. Often, its lack will be a deal breaker that disqualifies you from lucrative contracts with clients that demand strong security assurances as a baseline.

On the other hand, SOC 2 shows potential partners that your organization meets the rigorous compliance standards necessary to handle sensitive data. It unlocks new markets and larger opportunities that would otherwise be out of reach completely.

SOC 2 Compliance Strengthens Risk Management

The reality is that a single data breach can have devastating consequences, from financial losses to reputational damage and legal liabilities. SOC 2 compliance is one of the ways your organization steers clear of these dreaded scenarios.

SOC 2 controls are the difference between reactivity and proactivity. Rather than scrambling to respond to security incidents, they equip you to identify, assess, and mitigate risks before they escalate to full-blown catastrophes.

Along with minimizing vulnerabilities, SOC 2 compliance builds a security foundation that supports business continuity even as new threats emerge.

SOC 2 Audit Prep Best Practices

Below we outline a few steps to tackle before you undergo the formal SOC 2 audit.

1. Build a Compliance Team

Before diving into the audit process, ensure you have a solid compliance team in place. This team will comprise a mix of technical roles (engineers, IT specialists) and non-technical roles (HR specialists, administrative staff).

- **Compliance lead:** You can assign this role to a CISO, CTO, or IT department manager. The key is to tap someone who can speak to your current security processes and will be able to serve as a liaison between your team and the SOC 2 auditor.
- **IT and security personnel:** These team members will be charged with providing your organization's security and carrying out incident responses.
- **Legal team:** You'll also want to loop in members of your legal team to help you draft documentation and contracts and communicate with vendors as needed.
- **HR and administrative staff:** Since these team members grant employees access to sensitive data via access keys and login credentials, you'll be working closely with them to document their processes and identify any security concerns. They can also help with the development and distribution of security policies.

2. Avoid the Check-the-Box Mentality

It can be easy to treat SOC 2 like a series of steps to be checked off in order to achieve compliance. While a checklist like the one we've outlined above can be helpful in achieving SOC 2 compliance, this can lead some companies to think of compliance as a one-and-done event rather than something to continuously maintain.

Instead of looking at SOC 2 as the extent of your security program, view it as a baseline upon which you can tailor processes to not only meet SOC 2 requirements, but further fortify them when possible. For example, you might invest in a newer ransomware protection software or implement passwordless authentication to further improve your access management.

3. Build Out Your Security Tech Stack

To comply with SOC 2 requirements, you'll need to invest in a few tools (if you haven't already). Keep in mind that the types of tools and the features required will vary depending on your industry and the TSC you're measuring against.

Below are a few general tools you'll likely need to add to your tech stack:

- Password manager
- Web app firewall
- Vulnerability scanner
- Background check provider

Look for tools that integrate well with your current tools, work within your budget, and feature easy-to-use dashboards to improve company-wide adoption.

Streamline Your SOC 2 Compliance With Drata

As you can see, preparing for an SOC 2 audit requires quite a bit of work. Controls need owners, evidence needs structure, and auditors need access. And all of it needs to stay current, not just once a year but every day.

Drata brings that all into one place:

- **Automated evidence collection** pulls data directly from your systems, saving hours of manual screenshots and exports
- **Control monitoring** tracks key audit items in real time, so you catch issues before your auditor does
- **Audit Hub** gives your auditor direct access to mapped controls, documentation, and evidence *within the platform*
- **Trust Center** lets you prove compliance to customers instantly
- **Auditor Alliance** connects you with firms already familiar with Drata, so you can shorten the audit timeline and rest assured you're working with the best in their fields

Instead of managing compliance in spreadsheets, emails, and shared drives, Drata keeps the entire process audit-ready from day one.

Get Audit-Ready Faster With Drata's SOC 2 Compliance Solution

Book a demo of Drata's SOC 2 compliance solution to learn how to get audit-ready faster.

Schedule a Demo

SOC 2 Compliance: Frequently Asked Questions (FAQs)

Still have lingering questions about SOC 2 compliance? Below we answer some of the most common queries.

Who Needs SOC 2 Compliance?

Organizations that store, process, or manage customer data often need SOC 2 compliance. It's especially important for SaaS companies, cloud providers, and technology firms that handle sensitive or regulated information.

SOC 2 proves your organization's commitment to security and assures clients that you have strong controls in place to protect their data. Even if it's not legally required, many companies pursue SOC 2 to build trust and meet customer demands.

What are the Steps in the SOC 2 Compliance Process?

The SOC 2 compliance process consists of nine steps to prepare your organization for the audit:

- Determine if a Type 1 is necessary: Decide whether to start with a SOC 2 Type 1 audit, which assesses controls at a single point in time, or go directly to a Type 2, which reviews controls over a period.
- Determine your scope: Identify which Trust Services Criteria (TSC) to include and outline the in-scope system components, such as infrastructure, data, procedures, software, and people.
- Communicate processes internally: Make sure all key stakeholders understand the scope, objectives, and their roles throughout the compliance process.
- Perform a gap assessment: Review your current controls against SOC 2 requirements to identify where you fall short.
- Remediate control gaps: Implement missing controls, update policies, and formalize procedures to meet SOC 2 standards.
- Update your customers and prospects: Highlight the measures you have in place to keep their data safe.
- Monitor and maintain controls: Establish continuous monitoring processes to ensure that your controls are operating effectively and remain aligned with SOC 2 requirements.
- Find an auditor: Select a qualified auditor who understands your industry and can guide you through the audit process.
- Undergo the SOC 2 audit: Provide documentation for each control, participate in walkthroughs, and respond to any questions from the auditor to finalize the audit.

What's the Difference Between SOC 2 Type 1 and Type 2?

The main differences between SOC 2 Type 1 and Type 2 are timing and scope. A SOC 2 Type 1 report evaluates whether your controls are suitably designed to meet the applicable Trust Services Criteria at a specific point in time.

In contrast, a SOC 2 Type 2 report tests whether those controls are operating effectively over a period of time (typically three to 12 months). Because Soc 2 Type 2 compliance requires ongoing evidence and monitoring, it's more comprehensive and is often considered the gold standard for demonstrating compliance.

How Long Does SOC 2 Compliance Take?

The timeline for SOC 2 compliance depends on your organization's readiness and the type of audit you're pursuing. A SOC 2 Type 1 audit can take up to six months.

A SOC 2 Type 2 audit can take anywhere from three to 12 months to complete. The process can be faster if you already have mature controls in place or are using compliance automation tools to streamline evidence collection and monitoring.

Is There an Official SOC 2 Compliance Checklist?

Since every SOC 2 audit is unique, there's no official checklist published by the AICPA. Your checklist depends on your systems, business model, customer expectations, and the Trust Services Criteria you select. While the AICPA defines the criteria, it doesn't dictate how you meet them.

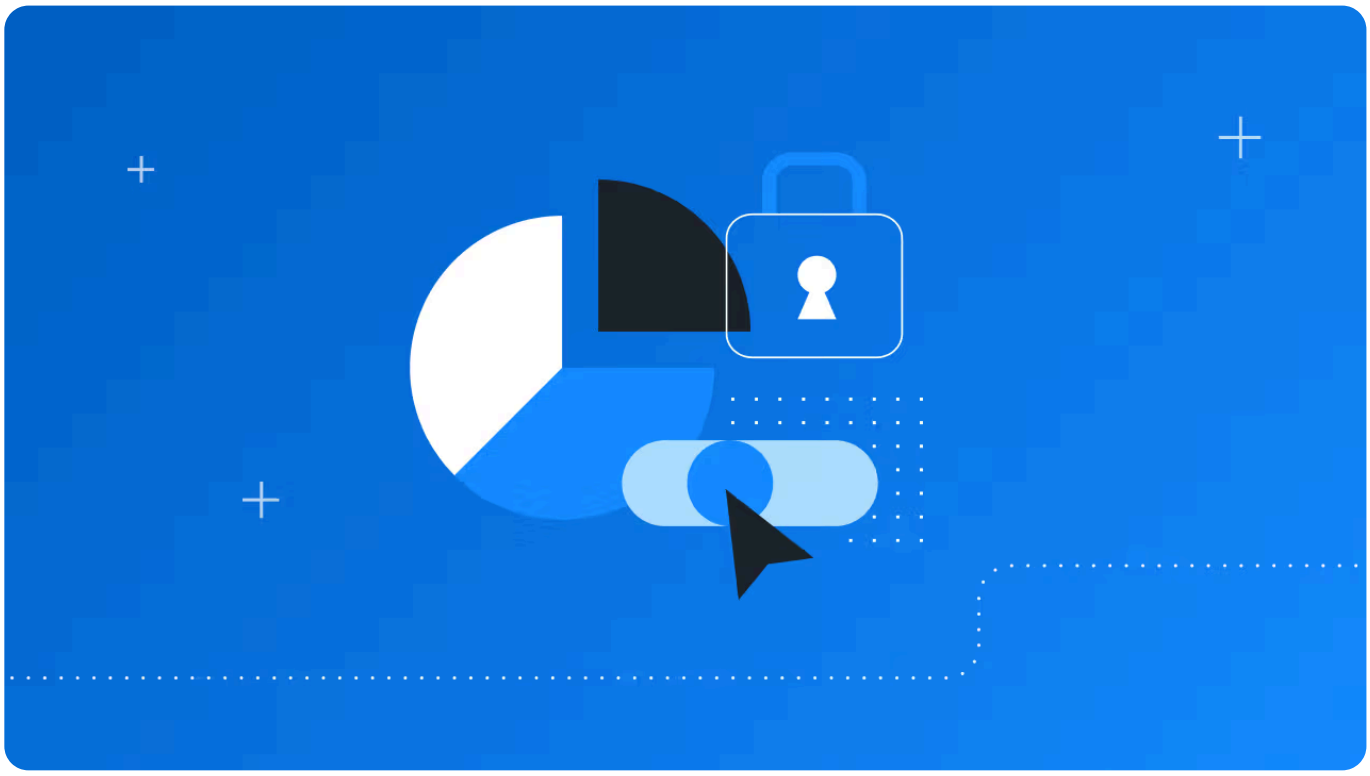
What Are the Trust Services Criteria?

The Trust Services Criteria (TSC), as defined by AICPA, are the five key areas used to evaluate SOC 2 compliance: Security, Availability, Processing Integrity, Confidentiality, and Privacy. Each criteria outlines specific controls needed to safeguard systems and data.

Organizations choose which criteria to include based on their services and customer needs, with Security always being a requirement.

Keep Reading

See More



ARTICLE

SOC 2 Compliance Automation Software: Everything You Need to Know

ARTICLE

ARTICLE

Earn Trust of Customers With SOC 2

Take Your Learning Further

Discover research, playbooks, checklists, and other resources on SOC 2 compliance.

Explore SOC 2 Hub

Solutions

Startup

Mid-Market

Enterprise

Drata Platform

Integrations

Frameworks

SOC 2

ISO 27001

HIPAA

GDPR

NIST AI Risk Management

FedRAMP

NIS 2

HITRUST

Custom Frameworks

All Frameworks

Resources

Blog

Events

Webinars

Reports

SOC 2 Hub

ISO 27001 Hub

Product Updates

Compliance Glossary

API Documentation

Company

Careers HIRING

Customers

Auditors

Partners

Press

Contact Us

Legal

Trust

Security And Compliance

Trust Center

System Status

Accessibility

© 2026 Drata Inc. All rights reserved

Cookie Preferences | Privacy Notice | Legal